PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Recommandations de sécurité TLS

03-350 ANSSI - Recommandations de sécurité relatives à TLS — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le protocole TLS assure la confidentialité et l'intégrité des flux tout en authentifiant systématiquement le serveur.
2. La confidentialité persistante est garantie par l'utilisation d'échanges Diffie-Hellman éphémères comme ECDHE ou DHE.
3. La validité des certificats est contrôlée via une chaîne de confiance, des listes de révocation ou le protocole OCSP.

Comparatif des sessions et IGC

Notion	À retenir
Session TLS < 1.2	ClientHello, ServerHello, Certificate, ServerKeyExchange (DH), ClientKeyExchange, ChangeCipherSpec et Finished. Nécessite une suite assurant la **PFS**.
Session TLS 1.3	Handshake en **un seul aller-retour**. Échange DH via extensions dès le **ClientHello**. Authentification via **Certificate** et **CertificateVerify** (chiffrés via **HKDF**).
Gestion des clés	Validité via **chaîne de confiance** vers racine. Révocation via **CRL** ou **OCSP** (ou **agrafage OCSP**). Détection via **Certificate Transparency**.

Synthèse de la négociation TLS

Notion	À retenir
Versions et clients	Privilégier **TLS 1.3**, **TLS 1.2** acceptable sous conditions. Proscrire **SSLv2, SSLv3, TLS 1.0, TLS 1.1**. Profil de compatibilité requis pour clients non maîtrisés.
Échange et authentification	Assurer la **PFS** via **ECDHE** (courbes `secp256r1`, `secp384r1`, `secp521r1`, `x25519`, `x448`) ou **DHE** toléré (**2048** bits min, **3072** bits après **2030**). Serveur : **ECDSA** ou **EdDSA** privilégiés ; **RSA** toléré (de préférence **RSASSA-PSS**).
Chiffrement et hachage	Privilégier **AES** (modes **GCM**, **CCM**) ou **ChaCha20**. Hachage : uniquement famille **SHA-2**. Proscrire **RC4, MD5, SHA-1**. Serveur doit imposer l'ordre de ses préférences.
Extensions protocole	Recommandées : `supported_groups`, `signature_algorithms`, `renegotiation_info`. Spécifiques : `supported_versions`, `key_share` (**TLS 1.3**). Déconseillées : `max_fragment_length`, `truncated_hmac`, `early_data`.
Sécurité additionnelle	Proscrire **compression TLS**. Tickets de session : durée **< 24 heures**. Éviter **0-RTT** (pas de protection anti-rejeu). Aléas : structure **32 octets** entièrement aléatoire préférée.

Attributs, extensions et révocation des certificats

Notion	À retenir
Attributs X509	Hachage **SHA-2**, validité **≤ 3 ans** (**825 jours** après **01/03/2018**), RSA **≥ 2048 bits**, ECDSA **≥ 256 bits**, exposant RSA **≥ $2^{16} + 1$**.
Extensions	Key Usage **critique** (**digitalSignature** + **keyEncipherment** serveur, **digitalSignature** client), EKU **non critique**, SAN **non critique** (1 FQDN min), AKI = SKI signataire, **CRLDP** ou **AIA** présents.
Contrôle et révocation	Chaînes **ordonnées/complètes** (sans racine), **OCSP stapling** préféré, mécanismes de **redondance**, **hard-fail** si info inaccessible, **Certificate Transparency** recommandé (rejeter **SCT** invalide).

Pièges et confusions

- ⚠ Croire que la simple désactivation par défaut des versions obsolètes suffit au lieu de leur retrait complet pour éviter la dégradation des paramètres.
- ⚠ Ignorer que la prise en charge de SSLv2 peut compromettre des sessions établies avec des versions ultérieures via l'attaque DROWN.
- ⚠ Utiliser le mode RSASSA-PKCS1-v1_5 avec un petit exposant RSA, ce qui expose à une attaque de forgerie de signature.
- ⚠ Adopter un comportement soft-fail face à un service de révocation indisponible, permettant l'usurpation d'identité.

Sigles et définitions

TLS	Protocole client-serveur assurant la confidentialité et l'intégrité des flux réseau et empêchant leur rejeu.
SSL	Protocole prédécesseur de TLS, apparu en 1995 et aujourd'hui obsolète.
Handshake TLS	Phase initiale de la session au cours de laquelle sont négociés la version du protocole, la suite cryptographique et les paramètres d'échange de clé.
PFS	Confidentialité persistante garantissant que la compromission de la clé privée du serveur ne permet pas de déchiffrer des sessions passées.
CRL	Fichier listant les certificats révoqués par une autorité de certification.
OCSP	Protocole permettant de vérifier en ligne la validité d'un certificat auprès d'un répondeur dédié.
Certificate Transparency	Programme créant des registres publics de certificats X509 émis, vérifiables par des SCT.

Auto-test

1. Quelles sont les variantes éphémères des algorithmes d'échange de clé Diffie-Hellman ?
2. Quelle famille de hachage est la seule recommandée ?
3. Quelle est la durée maximale de validité d'un certificat X509 ?
4. Que permet l'agrafage OCSP ?
5. Quelle est la taille préférée pour la structure des aléas ?

Réponses : **1.** ECDHE et DHE. · **2.** La famille SHA-2. · **3.** ≤ 3 ans (825 jours après 01/03/2018). · **4.** Le serveur fournit directement une réponse OCSP dans les extensions TLS au client. · **5.** 32 octets entièrement aléatoire.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.